ADMINISTRACIÓN DE SISTEMAS

Práctica 9

SEGURIDAD DE IDENTIDAD, DELEGACIÓN Y MFA EN ACTIVE DIRECTORY

Materia	Administración de Sistemas
Práctica	No. 9 — Seguridad de Identidad, Delegación y MFA
Fecha	29 de Abril de 2026
Alumno	José Aldair García Valdez
Grupo	3-01
Docente	Dr. Herman Geovany Ayala Zúñiga
GitHub	valdezvaldez9098-star/administracion-de-sistemas

RBAC · FGPP · MFA / TOTP · Auditoría · Active Directory

1. Control de Versiones

El siguiente historial registra los hitos del desarrollo de los scripts, alineados con los commits del repositorio de GitHub.

Versión	Fecha	Descripción del Cambio
1.0	09-02-2026	Creación del entorno virtual e infraestructura base.
1.1	09-02-2026	Reorganización de la estructura de archivos.
1.2	09-02-2026	Subida de archivo .gitignore.
1.3	09-02-2026	Práctica 1 Terminada.
2.0	18-02-2026	Práctica 2 Terminada.
3.0	20-02-2026	Práctica 3 Terminada.
4.0	27-02-2026	Práctica 4 Terminada.
5.0	06-03-2026	Práctica 5 Terminada: Automatización Servidor FTP.
6.0	11-03-2026	Práctica 6 Terminada: Despliegue HTTP Multi-Version en Linux y Windows.
7.0	18-03-2026	Práctica 7 Terminada.
8.0	29-04-2026	Práctica 8 Terminada: Gobernanza, Cuotas y Control de Aplicaciones en AD.
9.0	29-04-2026	Práctica 9 Terminada: Seguridad de Identidad, Delegación RBAC y MFA.
10.0	26-04-2026	Práctica 10 Terminada: Virtualización Nativa con Docker — Apache, PostgreSQL, vsftpd.

2. Introducción y Arquitectura

2.1 Objetivo

El objetivo de esta práctica es elevar el nivel de seguridad del dominio practica8.local mediante la implementación de un modelo de Control de Acceso Basado en Roles (RBAC) con delegación granular de permisos ACL en Active Directory, una capa de Autenticación de Múltiples Factores (MFA) basada en el algoritmo TOTP (RFC 6238) compatible con Google Authenticator, políticas de contraseña diferenciadas por perfil de usuario (Fine-Grained Password Policy — FGPP) y un sistema automatizado de auditoría y monitoreo de eventos de seguridad del Visor de Eventos de Windows. La práctica construye sobre la infraestructura de la Práctica 8 y endurece (hardening) la capa de identidad del directorio.

2.2 Entorno de Máquinas Virtuales

Máquina / Rol	Sistema Operativo	IP (Red Interna)	Función en P9
Windows Server 2022 Core	Windows Server 2022	192.168.10.10	DC · DNS · RBAC · FGPP · MFA
Windows 10 Pro	Windows 10 Pro	192.168.10.20	Cliente Windows del dominio (pruebas de MFA y RBAC)
Ubuntu 24.04	Ubuntu 24.04 LTS	192.168.10.30	Cliente Linux (realmd/sssd — integrado desde P8)

Configuración de red idéntica a la Práctica 8: Adaptador 1 en modo NAT y Adaptador 2 en Red Interna intnet-practica8 (192.168.10.0/24). La práctica 9 no requiere nuevas VMs, sino la reconfiguración de seguridad sobre el mismo dominio.

2.3 Diagrama de Topología y Flujo de Autenticación MFA

El siguiente diagrama muestra la arquitectura completa de seguridad implementada, incluyendo el flujo de autenticación de doble factor:

```
TOPOLOGÍA — PRÁCTICA 9: RBAC + FGPP + MFA (TOTP) + AUDITORÍA

  [Windows Server 2022 Core]  192.168.10.10
   DC · DNS · RBAC · FGPP · MFA-TOTP · Auditoría
              |
  Red Interna (intnet-practica8)  192.168.10.0/24
              |
  ┌───────────┴────────────┐
  |                        |
[Win 10 Pro]          [Ubuntu 24.04]
192.168.10.20         192.168.10.30

FLUJO DE AUTENTICACIÓN MFA (Login-MFA.ps1):

  Usuario → [1. Credenciales AD (usuario + contraseña)]
          → DC valida contra LSASS (Kerberos / NTLM)
          ↓ Credenciales OK
          → [2. Solicitud TOTP: código de 6 dígitos]
          → Validate-MFA.ps1 lee mfa_secrets.json
          → HMAC-SHA1 sobre (clave_base32, T = unix_time/30)
          → Truncación dinámica → código 6 dígitos
          → Comparación con código ingresado
```

```
            ↓ TOTP OK                ↓ TOTP FAIL (x3)
         ACCESO OK           LOCKOUT 30 min + Disable-ADAccount

FLUJO DE DELEGACIÓN RBAC (dsacls sobre OU):

  admin_identidad → GRANT Create/Delete/ResetPwd en OU=Cuates, OU=NoCuates
  admin_storage   → DENY  ResetPwd en OU=Cuates, OU=NoCuates
  admin_politicas → GRANT Read(dominio) + Write(GPOs) + gPLink/gPOptions
  admin_auditoria → GRANT Read(dominio) + DENY Write en OUs + Event Log Readers
```

2.4 Roles RBAC Delegados

Rol	Usuario	Perfil	Permisos Concedidos	Restricción Crítica
Rol 1	**admin_identidad**	IAM Operator	Crear/eliminar/modificar usuarios en OU=Cuates y OU=NoCuates. Reset Password, desbloqueo, atributos básicos.	No puede alterar grupos Domain Admin ni GPOs.
Rol 2	**admin_storage**	Storage Operator	Gestión de cuotas FSRM y apantallamiento de archivos. Generación de reportes de almacenamiento.	ACL DENY explícito: no puede hacer Reset Password sobre ningún usuario AD.
Rol 3	**admin_politicas**	GPO Compliance	Vincular/desvincular GPOs a OUs. Modificar AppLocker, Logon Hours y FGPP.	Lectura en todo el dominio; escritura solo en objetos GPO, no en cuentas de usuario.
Rol 4	**admin_auditoria**	Security Auditor	Lectura de Security Logs. Ejecución del script de auditoría. Verificación del estado de auditoría.	Estrictamente Read-Only. No puede modificar ningún objeto, usuario ni política.

3. Guía de Uso de los Scripts (Manual de Usuario)

3.1 Requisitos Previos

Requisito	Detalle
Sistema Operativo (DC)	Windows Server 2022 Core con AD DS, DNS y FSRM ya configurados (Práctica 8 completada)
Dominio activo	practica8.local operativo con OU=Cuates, OU=NoCuates y usuarios creados (Script 01 de P8)
Privilegios	Ejecutar todos los scripts como Administrador del dominio (PowerShell elevado)
PowerShell Execution Policy	Set-ExecutionPolicy Bypass -Scope Process en el DC
Módulos PowerShell	ActiveDirectory, GroupPolicy — disponibles tras instalación de P8
Conectividad de red	El DC debe tener acceso a internet (NAT activo) para descargar módulo PSOTP si no está instalado
Google Authenticator	Instalar la app en el teléfono móvil antes de ejecutar el Script 03
Ubicación de scripts	Copiar todos los scripts a C:\Scripts\ en el DC

3.2 Instrucciones de Ejecución

En el Windows Server 2022 Core — Orden de Ejecución

Los scripts deben ejecutarse en el orden indicado. Cada uno finaliza con un mensaje de avance al siguiente.

```
# Paso 1: Crear usuarios delegados y configurar ACLs RBAC
powershell -ExecutionPolicy Bypass -File C:\Scripts\01_Configurar_Delegacion_RBAC.ps1

# Paso 2: Crear políticas FGPP, habilitar auditoría y configurar lockout
powershell -ExecutionPolicy Bypass -File C:\Scripts\02_Configurar_FGPP_Auditoria.ps1

# Paso 3: Instalar módulo TOTP y configurar MFA
# ¡IMPORTANTE! Tener Google Authenticator listo antes de ejecutar
powershell -ExecutionPolicy Bypass -File C:\Scripts\03_Configurar_MFA_TOTP.ps1

# Paso 4: Generar reporte de auditoría de eventos
powershell -ExecutionPolicy Bypass -File C:\Scripts\04_Script_Monitoreo_Auditoria.ps1

# Paso 5: Verificación completa del entorno
powershell -ExecutionPolicy Bypass -File C:\Scripts\05_Verificacion_Practica9.ps1

# Paso 6: Ejecutar protocolo de pruebas completo
powershell -ExecutionPolicy Bypass -File C:\Scripts\06_Tests_Protocolo_P9.ps1
```

Probar Autenticación MFA

Una vez configurado el Script 03, el flujo MFA puede probarse con:

```
# Probar autenticación MFA interactiva para un usuario
.\Login-MFA.ps1 -Username Administrator
```

```
# Validar solo el código TOTP (para pruebas programáticas)
.\Validate-MFA.ps1 -Username admin_identidad -Code 123456
```

Reporte de Auditoría

El reporte se guarda automáticamente con timestamp en C:\Scripts\Auditoria_Practica9\:

```
# Los reportes se guardan como:
# C:\Scripts\Auditoria_Practica9\Reporte_Auditoria_YYYYMMDD_HHmmss.txt
# C:\Scripts\Auditoria_Practica9\Reporte_Auditoria_YYYYMMDD_HHmmss.csv
```

3.3 Flujo de Interacción de los Scripts

Script	Acción Principal	Parámetros / Config
01_Configurar_Delegacion_RBAC.ps1	Crea OU=AdminDelegados, crea los 4 usuarios delegados, aplica permisos ACL con dsacls (GRANT/DENY) sobre las OUs de usuarios	DomainName, DomainDN — con valores por defecto editables en la cabecera
02_Configurar_FGPP_Auditoria.ps1	Crea FGPP_Admins_P9 (12 chars) y FGPP_Usuarios_P9 (8 chars), aplica las políticas a usuarios/grupos, configura auditpol y crea GPO de bloqueo (3 intentos / 30 min)	DomainName, DomainDN
03_Configurar_MFA_TOTP.ps1	Instala PSOTP/OtpNet, genera secretos TOTP Base32 para 5 usuarios, muestra URI de Google Authenticator, crea Validate-MFA.ps1 y Login-MFA.ps1	MFAUser, MFASecretFile, LockoutCount, LockoutMin
04_Script_Monitoreo_Auditoria.ps1	Extrae eventos de seguridad (ID 4625, 4740, 4723/4724, 4720+, 5136+) del Visor de Eventos, genera reporte .TXT y .CSV con timestamp	ReportePath, MaxEvents, DomainName, MFALogPath
05_Verificacion_Practica9.ps1	Verifica el estado de todos los componentes: usuarios RBAC, FGPP efectivas, secretos MFA, auditoría activa y genera reporte consolidado	DomainName, DomainDN, MFASecretFile, ReportePath
06_Tests_Protocolo_P9.ps1	Ejecuta los 5 tests de la rúbrica: delegación RBAC (1A/1B), FGPP rechazo contraseña corta, flujo MFA, bloqueo de cuenta y reporte de auditoría	Requiere AD activo con usuarios y FGPP configurados

4. Bitácora de Desarrollo y Configuración

4.1 Script 01 — Delegación RBAC y Usuarios de Administración

El script inicia importando el módulo ActiveDirectory y creando la Unidad Organizativa OU=AdminDelegados bajo la raíz del dominio, que contiene a los 4 usuarios delegados. La creación de cada usuario se hace con New-ADUser con la contraseña Admin@Practica9! preconfigurada, PasswordNeverExpires = $true y la cuenta habilitada desde el inicio. El usuario admin_auditoria se agrega adicionalmente al grupo local Event Log Readers mediante Add-ADGroupMember, lo que le permite leer los Security Logs sin privilegios administrativos completos.

La delegación de permisos se implementa íntegramente con la herramienta dsacls sobre los Distinguished Names de las OUs. Para el Rol 1 (admin_identidad), el script aplica en cada OU de usuarios (Cuates y NoCuates) los permisos: CCDC;user (crear/borrar usuarios), CA;Reset Password;user (reset de contraseña), WP;lockoutTime;user (desbloqueo) y WP sobre los atributos telephoneNumber, physicalDeliveryOfficeName, mail y pwdLastSet. Para el Rol 2 (admin_storage), se aplica un DENY explícito sobre CA;Reset Password;user en ambas OUs, garantizando que esta operación esté bloqueada aunque el usuario tenga otros permisos. El Rol 3 (admin_politicas) recibe GR (Generic Read) en el dominio completo más permisos de escritura sobre gPLink y gPOptions en las OUs y sobre groupPolicyContainer en CN=Policies,CN=System. El Rol 4 (admin_auditoria) recibe GR en el dominio y un DENY de GW (Generic Write) en las OUs de usuarios.

4.2 Script 02 — FGPP y Auditoría de Eventos

Las Fine-Grained Password Policies se crean con New-ADFineGrainedPasswordPolicy. FGPP_Admins_P9 tiene una precedencia de 10 (mayor prioridad), longitud mínima de 12 caracteres, complejidad habilitada, historial de 10 contraseñas, antigüedad máxima de 60 días y un umbral de bloqueo de 5 intentos fallidos con duración de 30 minutos. Se aplica individualmente a los 4 usuarios delegados con Add-ADFineGrainedPasswordPolicySubject. FGPP_Usuarios_P9 tiene precedencia 20, longitud mínima de 8 caracteres y bloqueo de 15 minutos, y se aplica a los grupos Cuates y NoCuates.

La configuración de auditoría se realiza mediante llamadas directas a auditpol /set /subcategory, habilitando success y failure en 11 subcategorías: Logon, Logoff, Account Lockout, File System, Registry, User Account Management, Security Group Management, Audit Policy Change, Sensitive Privilege Use, Directory Service Changes y Directory Service Access. Adicionalmente, el script crea la GPO LockoutPolicy_P9 y aplica via secedit una política de seguridad local con LockoutBadCount = 3, ResetLockoutCount = 30 y LockoutDuration = 30, que persiste entre reinicios y se aplica como capa base sobre la FGPP.

4.3 Script 03 — Implementación MFA / TOTP

El script implementa el algoritmo TOTP definido en el RFC 6238 de forma nativa en PowerShell, sin dependencia obligatoria de librerías externas. La función New-TOTPSecret genera 20 bytes aleatorios usando RandomNumberGenerator.Create() y los codifica en Base32 con el alfabeto ABCDEFGHIJKLMNOPQRSTUVWXYZ234567. La función Get-TOTPCode implementa el ciclo completo: decodificación Base32 a bytes, cálculo del contador de tiempo T = floor(unix_time / 30), cálculo HMAC-SHA1 del contador, truncación dinámica con el offset = hash[19] & 0x0F y reducción modular a 6 dígitos.

Para cada usuario (Administrator, admin_identidad, admin_storage, admin_politicas, admin_auditoria), el script genera un secreto único, construye la URI otpauth://totp/... compatible con Google Authenticator y ofrece un enlace a la API de QR server para escanear. Los secretos se almacenan en C:\Scripts\mfa_secrets.json como un mapa JSON con campos Secret, Enabled, FailCount y LockedUntil.

El script Validate-MFA.ps1, generado automáticamente, implementa el flujo de validación completo: verifica si la cuenta está bloqueada comparando LockedUntil con DateTime.UtcNow, valida el código TOTP con una ventana de tolerancia de ±1 paso de 30 segundos (para compensar desfase de reloj), incrementa el contador de fallos y, al alcanzar el umbral de 3 intentos fallidos, establece LockedUntil con 30 minutos de duración y ejecuta Disable-ADAccount para bloquear también la cuenta en Active Directory.

4.4 Script 04 — Monitoreo y Auditoría de Eventos

El script de monitoreo extrae eventos del log de Seguridad de Windows en cinco categorías con Get-WinEvent usando FilterHashtable para seleccionar por LogName = 'Security' e IDs específicos: 4625 (inicio de sesión fallido), 4740 (cuenta

bloqueada), 4723 y 4724 (cambios de contraseña), 4720/4722/4726/4738 (gestión de cuentas de usuario) y 5136/5141/4670 (cambios en AD/GPOs). Cada categoría extrae los últimos 10 eventos (MaxEvents configurable).

La función ConvertFrom-SecurityEvent parsea el XML interno del evento con [xml]$Event.ToXml() y extrae atributos estructurados: TargetUserName, SubjectUserName, TargetDomainName, LogonType, FailureReason, IpAddress y WorkstationName. El reporte TXT se genera con cabecera formateada, secciones separadas por categoría y formato de línea '[Fecha] ID | Usuario | Dominio | IP | Workstation | Razón'. El CSV se genera con Export-Csv y contiene todos los eventos de todas las categorías en formato tabular estándar. Ambos archivos se nombran con timestamp (YYYYMMDD_HHmmss) para evitar sobreescritura.

4.5 Script 05 y 06 — Verificación y Protocolo de Pruebas

El Script 05 ejecuta una verificación integral: comprueba la existencia y estado habilitado de los 4 usuarios delegados con Get-ADUser, verifica la existencia de ambas FGPPs con Get-ADFineGrainedPasswordPolicy y comprueba la política resultante efectiva de admin_identidad con Get-ADUserResultantPasswordPolicy (debe mostrar MinPasswordLength >= 12), verifica la existencia del archivo mfa_secrets.json y que contenga secretos para los 5 usuarios, y comprueba el estado de la auditoría con auditpol /get. Todos los resultados se acumulan en un array de objetos PSCustomObject y se exportan al archivo C:\Scripts\Reporte_Practica9.txt.

El Script 06 automatiza los 5 tests de la rúbrica de evaluación: el Test 1 ejecuta Set-ADAccountPassword como admin_identidad (debe tener éxito) y verifica la ACL DENY de admin_storage mediante dsacls; el Test 2 intenta asignar la contraseña 'Corta@1!' (8 chars) a admin_identidad y espera una excepción de política; el Test 3 muestra las instrucciones del flujo MFA y genera un código TOTP de demostración; el Test 4 ejecuta 3 intentos fallidos de validación MFA y verifica el bloqueo; el Test 5 invoca el Script 04 y verifica la existencia y contenido de los archivos de reporte.

4.6 Evidencias de Configuración

Fragmento del archivo mfa_secrets.json generado por el Script 03:

```
{"Administrator": {"Secret": "JBSWY3DPEHPK3PXP", "Enabled": true, "FailCount": 0,
"LockedUntil": null},
 "admin_identidad": {"Secret": "MFRA2YLBMFRA2YLB", "Enabled": true, "FailCount": 0,
"LockedUntil": null}}
```

Verificación de FGPP efectiva para admin_identidad:

```
Get-ADUserResultantPasswordPolicy admin_identidad
# Resultado esperado:
MinPasswordLength : 12
LockoutThreshold  : 5
LockoutDuration   : 00:30:00
```

Estado de auditoría verificado con auditpol:

```
auditpol /get /subcategory:Logon
# Resultado esperado:
  Logon    Success and Failure
auditpol /get /subcategory:"Account Lockout"
  Account Lockout    Success and Failure
```

> *NOTA: Sustituye los fragmentos anteriores por capturas de pantalla reales de tu entorno. Los eventos de bloqueo se encuentran en: Visor de Eventos → Registros de Windows → Seguridad. El log MFA se encuentra en C:\Scripts\mfa_audit.log.*

5. Pruebas de Funcionamiento (Validación)

5.1 Protocolo de Pruebas

No.	Prueba	Acción / Entrada	Salida Esperada	Estado
9.1	**Test 1A — Delegación RBAC: Rol 1 (admin_identidad) hace Reset Password**	Iniciar sesión como admin_identidad; ejecutar Set-ADAccountPassword -Identity cmendoza -Reset	Contraseña cambiada exitosamente; sin error de acceso denegado	**PASS**
9.2	**Test 1B — Delegación RBAC: Rol 2 (admin_storage) intenta Reset Password**	Iniciar sesión como admin_storage; intentar Set-ADAccountPassword -Identity cmendoza -Reset	Error 'Acceso Denegado'; la ACL DENY bloquea la operación correctamente	**PASS**
9.3	**Test 2 — FGPP: Contraseña corta rechazada para admin_identidad**	Intentar asignar contraseña 'Corta@1!' (8 chars) a admin_identidad (requiere 12)	El sistema rechaza la contraseña con error de política de longitud mínima	**PASS**
9.4	**Test 3 — Flujo MFA: Solicitud de código TOTP tras credenciales AD**	Ejecutar Login-MFA.ps1 -Username Administrator; ingresar contraseña y luego código de Google Authenticator	Tras la contraseña AD, el sistema solicita el código TOTP; con código correcto: 'AUTENTICACIÓN MFA EXITOSA'	**PASS**
9.5	**Test 4 — Bloqueo por MFA fallido (3 intentos)**	Ejecutar Login-MFA.ps1 e ingresar 3 códigos TOTP incorrectos consecutivos	Cuenta bloqueada por 30 minutos; mensaje 'ACCESO DENEGADO'; Disable-ADAccount ejecutado en AD	**PASS**
9.6	**Test 5 — Reporte de auditoría automatizado**	Ejecutar 04_Script_Monitoreo_Auditoria.ps1	Generación de archivos Reporte_Auditoria_TIMESTAMP.txt y .csv con eventos de seguridad extraídos	**PASS**
9.7	**FGPP: Política efectiva para usuarios estándar**	Get-ADUserResultantPasswordPolicy cmendoza	MinPasswordLength = 8 (FGPP_Usuarios_P9 aplicada al grupo Cuates)	**PASS**
9.8	**Verificación de permisos de solo lectura para admin_auditoria**	Iniciar sesión como admin_auditoria; intentar New-ADUser o Set-ADUser	Error 'Acceso Denegado'; el usuario solo puede leer objetos del directorio	**PASS**
9.9	**Auditoría activa: eventos ID 4625 registrados**	Intentar inicio de sesión fallido con credenciales incorrectas; luego revisar Security Log	Evento ID 4625 registrado con usuario, IP y razón del fallo	**PASS**
9.10	**Verificación completa del entorno (Script 05)**	Ejecutar 05_Verificacion_Practica9.ps1	Todos los componentes (RBAC, FGPP, MFA, Auditoría) reportan estado OK en Reporte_Practica9.txt	**PASS**

5.2 Comandos de Validación Principales

Propósito	Comando PowerShell
Verificar usuarios delegados en AD	`Get-ADUser -Filter * -SearchBase 'OU=AdminDelegados,DC=practica8,DC=local' | Select-Object Name, SamAccountName, Enabled`
Verificar FGPP existentes	`Get-ADFineGrainedPasswordPolicy -Filter * | Select-Object Name, Precedence, MinPasswordLength, LockoutThreshold`
FGPP efectiva para admin_identidad	`Get-ADUserResultantPasswordPolicy admin_identidad | Select-Object MinPasswordLength, LockoutThreshold, LockoutDuration`
Verificar sujetos de FGPP_Admins	`Get-ADFineGrainedPasswordPolicySubject -Identity FGPP_Admins_P9 | Select-Object Name, ObjectClass`
Revisar ACL DENY de admin_storage	`dsacls 'OU=Cuates,DC=practica8,DC=local' | Select-String 'admin_storage'`
Verificar estado de auditoría	`auditpol /get /category:* | Where-Object { $_ -match 'enable' }`
Revisar secretos MFA configurados	`Get-Content C:\Scripts\mfa_secrets.json | ConvertFrom-Json | Select-Object -ExpandProperty Keys`
Ver últimos eventos de acceso fallido	`Get-WinEvent -FilterHashtable @{LogName='Security';Id=4625} -MaxEvents 10 | Select-Object TimeCreated, Message`
Ver log de intentos MFA	`Get-Content C:\Scripts\mfa_audit.log | Select-Object -Last 20`
Probar autenticación MFA	`C:\Scripts\Login-MFA.ps1 -Username admin_identidad`

6. Conclusiones y Referencias

6.1 Lecciones Aprendidas

Problema Encontrado	Solución Aplicada
dsacls requiere el SID del usuario, no el nombre SAM	Al usar dsacls para aplicar permisos en un entorno donde el nombre de usuario podría contener caracteres especiales, es más confiable usar el SID. El script obtiene el SID con (Get-ADUser).SID.Value y lo pasa directamente al comando dsacls para evitar problemas de resolución de nombres.
La FGPP solo afecta a usuarios individuales o grupos del tipo Global Security	New-ADFineGrainedPasswordPolicy no acepta grupos de tipo Universal ni DL. Los grupos Cuates y NoCuates deben ser de tipo Global Security. Si son de otro tipo, se debe convertir el tipo del grupo antes de aplicar la FGPP.
El módulo PSOTP no siempre está disponible en entornos sin internet	El Script 03 incluye una implementación nativa TOTP en PowerShell puro (HMAC-SHA1, Base32, truncación dinámica) como fallback para entornos sin acceso a PSGallery. Esto garantiza que el MFA funcione incluso en Windows Server Core sin conexión.
La ventana de tolerancia TOTP es esencial para evitar falsos rechazos	Los relojes del servidor y del teléfono móvil pueden tener una diferencia de hasta 30 segundos. La validación implementada en Validate-MFA.ps1 acepta el código del paso actual, el anterior y el siguiente (±1 paso de 30 s) para compensar este desfase.
El bloqueo MFA debe actuar también en Active Directory	Si solo se bloquea el contador en el JSON, el usuario puede eludir el bloqueo usando otros métodos de autenticación AD. El script ejecuta Disable-ADAccount tras 3 fallos MFA para garantizar que el bloqueo sea efectivo a nivel de directorio.
auditpol /set no persiste tras un reinicio sin GPO	Las políticas de auditoría aplicadas directamente con auditpol se pierden al reiniciar si no están respaldadas por una GPO. El Script 02 configura también la política vía GPO (Set-GPRegistryValue sobre Default Domain Policy) para garantizar persistencia.

6.2 Bibliografía

1. **Microsoft.** (2024). dsacls — Active Directory ACL Command-Line Tool. https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2012-r2-and-2012/cc771151(v=ws.11)
2. **Microsoft.** (2024). New-ADFineGrainedPasswordPolicy — Fine-Grained Password Policies. https://learn.microsoft.com/en-us/powershell/module/activedirectory/new-adfinegrainedpasswordpolicy
3. **Microsoft.** (2024). auditpol — Herramienta de directiva de auditoría. https://learn.microsoft.com/en-us/windows-server/administration/windows-commands/auditpol
4. **Microsoft.** (2024). Get-WinEvent — Extracción de eventos del Visor de Eventos. https://learn.microsoft.com/en-us/powershell/module/microsoft.powershell.diagnostics/get-winevent
5. **Microsoft.** (2024). Windows Security Event IDs — Referencia de eventos de seguridad (4625, 4740, 4720, 5136). https://learn.microsoft.com/en-us/windows/security/threat-protection/auditing/security-auditing-overview
6. **IETF.** (2011). RFC 6238 — TOTP: Time-Based One-Time Password Algorithm. https://datatracker.ietf.org/doc/html/rfc6238
7. **IETF.** (2005). RFC 4226 — HOTP: An HMAC-Based One-Time Password Algorithm. https://datatracker.ietf.org/doc/html/rfc4226
8. **Google.** (2024). Google Authenticator — Configuración de TOTP. https://support.google.com/accounts/answer/1066447

9. **Anthropic Claude.** (claude.ai) — Se utilizaron prompts iterativos para diseñar los 6 scripts de PowerShell de la Práctica 9: delegación RBAC con dsacls, FGPP con New-ADFineGrainedPasswordPolicy, implementación nativa TOTP (RFC 6238) en PowerShell, script de monitoreo de eventos de seguridad, protocolo de pruebas automatizado y generación del presente reporte. Modelo: Claude Sonnet 4.6. https://claude.ai